



PROJECT BOOKLET / TECHNICAL & OPERATIONS REVIEW

# W10 Dashboard

รูปเล่มวิเคราะห์ระบบและคู่มือปฏิบัติการ

| รายการ        | รายละเอียด                                                     |
|---------------|----------------------------------------------------------------|
| ขอบเขต        | โค้ด แอปพลิเคชัน API data layer tests scripts และเอกสารโครงการ |
| สถานะอ้างอิง  | repository snapshot วันที่ 31 กรกฎาคม 2026                     |
| commit ล่าสุด | 0955f46   main   fix(ui): polish ot employee console chrome    |
| ผู้อ่านหลัก   | ผู้บริหารหน่วยงาน ผู้ดูแลระบบ นักพัฒนา และผู้ปฏิบัติงาน W10    |

เอกสารนี้สรุปจากระบบจริงโดยไม่เปิดเผยค่า *secret*, *token* หรือ *private key*

READING MAP

สารบัญและวิธีอ่าน

รูปเล่มนี้แบ่งเป็น 11 ส่วน เริ่มจากภาพรวมของระบบ ไปสู่การอ่านแต่ละ route, สถาปัตยกรรมข้อมูล, Shop Order แบบเจาะลึก, ผลตรวจคุณภาพ และข้อเสนอแนะสำหรับการดูแลระบบใน Production.

| ส่วน | หัวข้อ                    | คำตอบที่ผู้อ่านจะได้                               |
|------|---------------------------|----------------------------------------------------|
| 1    | บทสรุปผู้บริหาร           | ระบบทำอะไร เหมาะกับใคร และผลตรวจปัจจุบัน           |
| 2    | ขอบเขตและเทคโนโลยี        | โครงสร้าง repository, stack และขอบเขตการอ่าน       |
| 3    | เส้นทางใช้งานและ UI shell | 7 routes, navigation และสถานะการ migrate           |
| 4    | การทำงานของแต่ละหน้า      | Home, Purchasing, BEML, OT และ Shop Order          |
| 5    | สถาปัตยกรรมและแหล่งข้อมูล | Browser, Next.js API, Google Sheets/Drive          |
| 6    | Shop Order เจาะลึก        | CRUD, schema A-K, upload และ lifecycle             |
| 7    | ความปลอดภัยและความทนทาน   | validation, OAuth, WAF, logging และ failure modes  |
| 8    | การทดสอบและผลตรวจ         | tests, TypeScript, build, lint และ browser handoff |
| 9    | ข้อค้นพบและงานค้าง        | ความเสี่ยงและ technical debt ที่พบจากการอ่าน       |
| 10   | คู่มือ deploy และ runbook | ตั้งค่าเครื่อง, Vercel, OAuth และ cleanup          |
| 11   | ภาคผนวก                   | API reference, file map, glossary และแหล่งข้อมูล   |

**คำแนะนำ** ถ้าต้องการทำความเข้าใจเร็ว ให้เริ่มที่ส่วน 1, 3, 5 และ 6; ถ้ารับผิดชอบ Production ให้ต่อด้วยส่วน 7, 8, 9 และ 10.

01 / EXECUTIVE SUMMARY

บทสรุปผู้บริหาร

W10 Dashboard คือแดชบอร์ดปฏิบัติการภายในสำหรับทีมซ่อมบำรุงและงานธุรการของ W10 ใช้ Google Sheets เป็นแหล่งข้อมูลหลัก แล้วนำเสนอเป็นหน้าจอที่อ่านเร็วสำหรับติดตาม Work Order, สถานะจัดซื้อจัดจ้าง, คลังอะไหล่ BEML และ OT โดยแยกมุมมองพนักงานกับลูกจ้างอย่างชัดเจน.

จุดเด่นของระบบอยู่ที่การรวมข้อมูลจากหลายซิดไว้ใน route ที่ใช้งานซ้ำทุกวัน และการออกแบบ Shop Order รุ่น Next.js ให้มีการตรวจไฟล์แบบหลายขั้น, resumable upload, OAuth Drive แบบ scope ต่ำ, partial success เมื่อไฟล์แนบล้มเหลว และ cleanup ที่ย้ายไฟล์เข้า Trash อย่างหน่วงเวลา.

**ข้อสรุปสั้น** แกนธุรกิจและการทดสอบของ Shop Order มีความเป็นระบบสูง แต่ทั้ง repository ยังมี lint baseline ที่ไม่ผ่าน, การย้าย UI shell ยังอยู่เพียง pilot route และยังมี public-access boundary ที่ต้องบริหารด้วย URL/WAF.

ตัวเลขสำคัญจาก snapshot นี้

| ค่า    | ความหมาย                            | รายละเอียด                                                                               |
|--------|-------------------------------------|------------------------------------------------------------------------------------------|
| 7      | หน้าใช้งานหลัก                      | /, /purchasing, /purchasing-all, /beml-inventory, /ot-summary, /ot-employee, /shop-order |
| 12     | API route handler                   | รวม route หลักของ dashboard, OT, purchasing, inventory และ Shop Order                    |
| 25     | test files                          | ผลรันจริงของ Vitest                                                                      |
| 270    | tests passed                        | unit, component, API และ repository-style tests                                          |
| 10 MB  | ขนาดไฟล์แบบสูงสุด                   | JPEG, PNG, WebP และ PDF สำหรับ Shop Order                                                |
| 30 วัน | ระยะหน่วงก่อนย้ายไฟล์เก่าเข้า Trash | เฉพาะไฟล์ที่ OAuth ของระบบเป็นเจ้าของ                                                    |

ผลตรวจที่ยืนยันได้

| สถานะ   | คำสั่งหรือกิจกรรม         | ผล                                                                  |
|---------|---------------------------|---------------------------------------------------------------------|
| PASS    | npm run test:unit         | 25 files / 270 tests                                                |
| PASS    | npm run test:oauth-setup  | 5 tests                                                             |
| PASS    | npx tsc --noEmit          | ไม่มี output error                                                  |
| PASS    | npm run build             | Next.js 16.2.12, production build สำเร็จ                            |
| PASS    | scoped ESLint             | shell/navigation/route pilot ผ่าน                                   |
| FAIL    | npm run lint              | 144 errors / 10 warnings ทั้ง repository                            |
| PENDING | browser manual acceptance | มี HTTP smoke/build baseline แต่viewport/focus/console checks ยังรอ |

## 02 / SCOPE &amp; STACK

## ขอบเขตการอ่านและเทคโนโลยี

การวิเคราะห์ครอบคลุม source code ใน app, components, lib และ scripts; test files; เอกสาร README, PRODUCT, CONTEXT, specs, plans และ verification handoff; ตลอดจน configuration ที่เกี่ยวข้อง. ไม่อ่านเนื้อหาใน node\_modules และ .next เพราะเป็น dependency/build output และไม่เปิดเผยค่าใน .env.local.

| ชั้นระบบ    | เทคโนโลยีและบทบาท                                                        |
|-------------|--------------------------------------------------------------------------|
| Runtime     | Next.js 16.2.12 App Router, React 19.2.4, TypeScript strict              |
| Styling     | Tailwind CSS 4, app/globals.css, Prompt ผ่าน next/font/google            |
| Interaction | Framer Motion, Lucide React, custom responsive dialogs                   |
| Charts      | Highcharts + highcharts-more, Recharts, react-d3-speedometer             |
| Data        | googleapis, Google Sheets Service Account, Google Drive OAuth drive.file |
| Testing     | Vitest 4.1.10, Testing Library, jsdom, Node test runner                  |
| Deploy      | Vercel, vercel.json cron สำหรับ /api/shop-order/cleanup                  |

## โครงสร้าง repository แบบอ่านเร็ว

| โฟลเดอร์          | หน้าที่                                                      |
|-------------------|--------------------------------------------------------------|
| app/              | routes, page entry, API route handlers, global layout/style  |
| components/       | navigation, AppShell, page header, charts และ Shop Order UI  |
| lib/              | Google Sheets adapter และ domain/repository ของ Shop Order   |
| scripts/          | OAuth setup utility และ Node test                            |
| docs/superpowers/ | design specs, implementation plans, verification handoff     |
| public/picture/   | โลโก้/ภาพประกอบของ W10 และทีมงาน                             |
| scratch/          | เครื่องมือ debug/ตรวจสอบข้อผิดพลาด ไม่ใช่ runtime production |

**หลักการอ่าน** ค่าต่าง ๆ ที่มาจาก Google Sheets ถูก map ด้วยตำแหน่งคอลัมน์/แถวที่กำหนดใน code; ดังนั้นชื่อ tab, range และโครงสร้างจัดเป็น dependency เชิงปฏิบัติการ ไม่ใช่เพียงรายละเอียดการตั้งค่า.

## Product intent

- ผู้ใช้หลักคือเจ้าหน้าที่ W10 maintenance และ administrative staff ที่ต้องตรวจสอบและสถานะงานระหว่างวัน.

- คำศัพท์ Employee, Contractor, OT Summary และ ETAS Scan Data ถูกกำหนดไว้ใน CONTEXT.md เพื่อไม่ให้มุมมองข้อมูลคนละประเภทปะปนกัน.
- แนวทาง UI คือ operational, direct, familiar; หลีกเลี่ยง marketing-style landing page และ motion ที่ทำให้การอ่านช้าลง.

### 03 / ROUTES & SHELL

## เส้นทางใช้งานและ UI shell

ระบบมี canonical navigation ที่รวมไว้ใน components/navigation/navigationDestinations.ts และใช้ซ้ำทั้ง dropdown แบบเดิมกับ AppShell ใหม่. NavigationMenu รองรับ hover, click/touch, outside pointer, Escape, focus return, current-route state และ reduced motion.

| Route           | ชื่อหน้า                | หน้าที่                                                | Chrome ปัจจุบัน |
|-----------------|-------------------------|--------------------------------------------------------|-----------------|
| /               | W10 Dashboard           | ยอด W/O, status, group, equipment, load factor         | legacy          |
| /purchasing     | การจัดซื้อจัดจ้าง       | สรุปหมวด, status, gauges, purchase table               | legacy          |
| /purchasing-all | สถานะการซื้อจ้างทั้งหมด | ภาพรวมทั้งหมด ใช้ purchasing content แบบ fixed filters | legacy          |
| /beml-inventory | คลังอะไหล่ BEML         | stock map, health ring, inventory table/modal          | legacy          |
| /ot-summary     | สรุป OT ลูกจ้าง         | OT ลูกจ้าง, ETAS scan, error tables                    | legacy          |
| /ot-employee    | สรุป OT พนักงาน         | OT พนักงาน, ETAS scan, error tables                    | console pilot   |
| /shop-order     | Shop Order              | CRUD, filter, summary, attachment workflow             | legacy          |

## ภาพรวมการ migrate shell

ShellMigrationGate ใน app/layout.tsx อ่าน pathname แล้วห่อเฉพาะ route ที่อยู่ใน consoleRoutes. ณ snapshot นี้ consoleRoutes มีเพียง /ot-employee; route อื่นยัง render children แบบเดิม. นี่เป็นการ rollout แบบ phased ตามแผนไม่ใช่การย้ายครบทั้งระบบ.

| ส่วน               | พฤติกรรมปัจจุบัน                                                                |
|--------------------|---------------------------------------------------------------------------------|
| Shared shell       | Sidebar desktop 240px, MobileTopBar, MobileNavigationDrawer                     |
| PageHeader         | title, description, sync status, filters/actions slot, refresh state            |
| RouteChromeAdapter | เลือก legacy หรือ console แบบ explicit                                          |
| Pilot coverage     | /ot-employee ผ่าน AppShell; /ot-summary ยัง legacy                              |
| Migration plan     | ต่อไป /ot-summary -> BEML -> purchasing-all -> purchasing -> home -> Shop Order |

**ข้อสังเกต** เอกสาร redesign ระบุเป้าหมายให้ครบ 7 routes แต่ code snapshot ยังเปิด shell เพียง pilot route. ผู้ดูแลควรถือว่างาน migrate UI ยังไม่ complete แม้ production build จะผ่าน.

## Responsive และ accessibility

- Desktop ใช้ Sidebar; mobile ใช้ drawer พร้อม overlay, Escape, focus เข้า close button, focus กลับ trigger และ body-scroll lock.
- ทุก route ใช้ Next Link สำหรับ internal navigation และ current route สื่อด้วย aria-current พร้อม cue มากกว่าสื่ออย่างเดียว.
- globals.css กำหนด Prompt, EGAT blue/amber/green/rose, focus ring 3px และ prefers-reduced-motion fallback.

## 04 / PAGE WALKTHROUGH

### การทำงานของแต่ละหน้า

#### 4.1 หน้าหลัก /: Work Order Operations

หน้า Home เรียก /api/dashboard และรีเฟรชอัตโนมัติทุก 30 วินาที พร้อมตัวเลือกปี/เดือนที่อัปเดตค่า filter ในจิตเมื่อผู้ใช้เลือกใหม่. หน้าแสดง status W/O (SAP, Pending, Finish), กลุ่ม W11-W14, ขอบรวม, equipment breakdown และ Load Factor/Man.

| ชุดข้อมูล         | การนำเสนอ                                                      |
|-------------------|----------------------------------------------------------------|
| Operation status  | pie chart + total + progress cards สำหรับ Pending, Finish, SAP |
| W/O by group      | การ์ด W11-W14 พร้อม entrance/left/finish/other finish/out      |
| Work by group     | Highcharts column + ตาราง equipment ต่อ W11-W14                |
| Load Factor / Man | 4 gauge ต่อกลุ่ม: พนักงาน/ลูกจ้าง ปกติ และ +OT                 |

#### 4.2 Purchasing และ Purchasing All

app/purchasing/page.tsx เป็น reusable PurchasingPageContent ที่รับ apiPath, title, fixedFilters, gauge panel, table column count และ color theme. /purchasing ใช้ข้อมูลสรุปแบบ gold theme; /purchasing-all reuse component เดิมด้วย teal theme และ fixed filters.

- กราฟหมวดการซื้อ/จ้างเป็น donut 3D; กราฟสถานะเป็น column 3D ที่คลิกเพื่อ filter ตาราง.
- ค้นหาครอบคลุมค่าใน purchase row ทั้งหมด; filter status ใช้ normalization เพื่อลดปัญหาช่องว่าง/คำนวณหน้าตัวเลข.
- หน้าโหลดข้อมูลซ้ำทุก 30 วินาที และเรียก /api/purchasing หรือ /api/purchasing-all แบบ no-store.

**ข้อควรระวังด้าน concurrency** ปี/เดือนของ purchasing ถูกเขียนลงเซลล์ filter กลางใน Google Sheet และรอสูตรคำนวณประมาณ 4 วินาที; ผู้ใช้หลายคนอาจกระทบ filter ของกันและกัน.

### 4.3 BEML Inventory

หน้า /beml-inventory เรียก /api/beml-inventory ซึ่งอ่าน tab PrintCheck และ map หัวคอลัมน์ตามชื่อภาษาไทย/อังกฤษ. หากไม่มี GOOGLE\_BEML\_INVENTORY\_SHEET\_ID จะใช้ deterministic demo data 76 รายการและแสดง warning ชัดเจน.

| มุมมอง                | ความสามารถ                                                                          |
|-----------------------|-------------------------------------------------------------------------------------|
| Dashboard             | Bin map แบบคลิกดูรายละเอียด, KPI ทั้งหมด/ปกติ/ใกล้หมด/หมด และ health ring           |
| Inventory             | ตาราง desktop และ mobile cards พร้อม sort ตาม code, P/N, name, system, balance, MIN |
| Low stock / Out stock | tab และ status filter สำหรับรายการต่ำกว่า MIN หรือ balance เป็น 0                   |
| Detail modal          | แสดง balance, MIN, MAX, gap ต่ำกว่า MIN, action และคำแนะนำ                          |

### 4.4 OT Summary และ OT Employee

ทั้งสองหน้าใช้ OtSummaryContent จาก app/ot-summary/page.tsx และเรียก /api/ot-summary. query workerType ทำให้ API โหลดข้อมูลเฉพาะ employee หรือ contractor ได้ แม้หน้า legacy default จะเป็น contractor และหน้า /ot-employee จะเป็น employee.

- แยกตารางตาม W11-W14 และมี all-total section.
- ข้อมูล contractor มี holidayHours, 1x, 1.5x, total money และ 3x; employee มี total และ total2.
- ETAS scan tables และ Check OT Error tables แสดงต่อกลุ่ม โดยใช้ name-to-group map ช่วยจัดกลุ่ม error ให้ตรงกับ summary.
- source-sheet links ช่วยเปิดชี้ค้นทางจากหน้าเว็บโดยตรง.

### 4.5 Shop Order

Shop Order เป็นหน้าที่มี interaction สูงสุด: ตารางและ pagination อยู่ซ้าย, summary rail อยู่ขวาบน desktop; บน mobile summary จะขึ้นก่อนตาราง. ผู้ใช้ค้นหา/กรอง, เปิดรายละเอียด, เพิ่ม, แก้ไข, ลบ และแนบไฟล์ได้.

| ส่วน UI | พฤติกรรม                                                                   |
|---------|----------------------------------------------------------------------------|
| Toolbar | query, ปี พ.ศ., เดือน, สถานะ, refresh, clear และเพิ่ม                      |
| Table   | sort ใหม่สุดก่อน, sticky header, horizontal scroll, 20 รายการต่อหน้า       |
| Summary | ทั้งหมด/รอดำเนินการ/เสร็จสิ้น, doughnut chart และ top 6 receiving units    |
| Form    | CustomSelect, CustomDatePicker, drag/drop file, image preview และ progress |
| Detail  | thumbnail ผ่าน authenticated proxy, edit, delete confirmation              |

## 05 / ARCHITECTURE &amp; DATA

## สถาปัตยกรรมและแหล่งข้อมูล

ระบบใช้โครงสร้าง route-centric: page client state ทำหน้าที่แสดงผลและ filter; API Route Handler ทำหน้าที่อ่าน/เขียน/normalize; lib/googleSheet.ts และ lib/shop-order/repository.ts ทำหน้าที่เป็น server-side integration boundary.

## แผนภาพการไหลของข้อมูล

| Browser UI                                                     | Next.js server                                        | Google services                                                         |
|----------------------------------------------------------------|-------------------------------------------------------|-------------------------------------------------------------------------|
| 7 pages<br>filters, charts, tables<br>dialogs, upload progress | Route Handlers<br>data mapping<br>domain + repository | Sheets Service Account<br>Drive OAuth drive.file<br>Vercel Cron cleanup |

ข้อมูลทั่วไปใช้ Google Sheets เป็น source of truth. ไฟล์แนบ Shop Order มีเส้นทางเฉพาะ: server เปิด session, browser ส่ง bytes ผ่าน upload proxy ไป Google Drive, แล้ว server verify/finalize ก่อนบันทึก canonical URL ลงซีดี.

## API และ data source matrix

| Endpoint                            | แหล่งข้อมูล                                    | ผลลัพธ์หลัก                                  |
|-------------------------------------|------------------------------------------------|----------------------------------------------|
| GET /api/dashboard                  | Dashboard W10 All + Dashboard W10 All info     | status, groupStats, equipment, gauges        |
| GET /api/purchasing                 | Dashboard W10 All + info                       | gauges, charts, purchaseList                 |
| GET /api/purchasing-all             | Dashboard W11 PRPO infoAll                     | charts, purchaseList แบบ all                 |
| GET /api/beml-inventory             | PrintCheck ของ BEML sheet                      | inventory rows + systems; demo fallback      |
| GET /api/ot-summary                 | OT employee/contractor + ETAS + Check OT Error | employees, contractors, ETAS, errors, totals |
| GET /api/shop-order                 | Order1 + DepartmentList + ReceiverList         | orders, departments, receivers               |
| POST /api/shop-order/upload-session | Google Drive OAuth                             | fileId, uploadUrl, expiresAt                 |
| GET /api/shop-order/cleanup         | Google Drive OAuth + Vercel Cron               | aggregate cleanup counters                   |

## Google Sheets adapter

- getSheetsClient ใช้ JWT Service Account และ scope spreadsheets เท่านั้น.
- lib/googleSheet.ts มี helper แยกสำหรับ dashboard, purchasing, OT, ETAS และ BEML inventory.
- ข้อมูลจำนวนมากถูก parse จากตำแหน่ง index ของ range ที่กำหนดตายตัว จึงต้องควบคุม schema ของซีดีและห้ามย้ายคอลัมน์โดยไม่แก้ mapping.

- date values ของ Shop Order ใช้ Google serial number และถูกแปลงเป็น ISO/Gregorian ก่อนแสดงเป็น พ.ศ.

## 06 / SHOP ORDER DEEP DIVE

## Shop Order เงิงลึก

Shop Order เป็นโมดูลที่มีการแบ่ง boundary ชัดที่สุดในโครงการ: domain utilities, file rules, OAuth classification, upload client, repository, route handlers และ UI components แยกกัน ทำให้ทดสอบได้ตั้งแต่ pure function จนถึง integration-style repository.

### 6.1 โครงสร้างซีต Order1 A-K

| คอธัมนั้ | ฟิลด์         | กตึกา                                                 |
|----------|---------------|-------------------------------------------------------|
| A        | no            | stable sequence; append แล้วอ่าน row จริงก่อนกำหนดเลข |
| B        | from          | server-enforced เป็น หสบ-ช.                           |
| C        | to            | ต้องพบใน DepartmentList                               |
| D        | number        | ตัวเลข ASCII 6 หลัก                                   |
| E        | dateIn        | วันที่รับ; เขียนเป็น serial + format dd/MM/yyyy       |
| F        | subject       | เรื่อง; ต้องไม่ว่าง                                   |
| G        | receivingUnit | หน่วยงานรับ; ใช้คำนวณ popular units                   |
| H        | receiverName  | ผู้รับ; มี ReceiverList เป็น suggestion               |
| I        | dateOut       | วันที่ออก; มีค่า = เสร็จสิ้น, ว่าง = รอดำเนินการ      |
| J        | note          | หมายเหตุ                                              |
| K        | fileUrl       | canonical Drive webViewLink หรือว่าง                  |

### 6.2 CRUD flow

1. ผู้ใช้กรอกข้อมูลและเลือกไฟล์; client ตรวจสอบรูปแบบไฟล์และแสดง preview ก่อนเรียก mutation.
2. POST upload-session ส่งเฉพาะ orderNumber, name, mimeType, size; server สร้าง Drive file ID และ resumable session.
3. Browser PUT ไฟล์ไป /api/shop-order/upload-proxy; upload client รายงาน progress และ retry เฉพาะ network/timeout/429/5xx สูงสุด 3 attempts.
4. POST/PATCH /api/shop-order ส่ง order และ uploadedFileId แบบ optional; repository ตรวจสอบ department, date, file metadata, parent, lifecycle และ leading bytes.
5. เมื่อผ่านจึงเปิด permission anyone/reader, เปลี่ยน lifecycle เป็น active และเขียน URL ลง Order1; ถ้าไฟล์ไม่ผ่านจะบันทึก order ต่อโดย K ว่างและคืน partial-success.
6. DELETE จะ clear A-K ของ row เดิม ไม่ลบ row เพื่อหลีกเลี่ยง sequence shift จาก concurrent request; ไฟล์ OAuth เดิมถูก schedule-delete 30 วัน.

## 6.3 Attachment lifecycle

| สถานะ                   | เกิดเมื่อ                               | metadata             | การจัดการ                              |
|-------------------------|-----------------------------------------|----------------------|----------------------------------------|
| <b>pending</b>          | สร้าง session แล้ว                      | pendingSince         | cleanup เมื่ออายุ >= 24 ชั่วโมง        |
| <b>active</b>           | verify + permission + Sheet link สำเร็จ | finalizedAt          | ใช้งานเป็นไฟล์แนบปัจจุบัน              |
| <b>scheduled_delete</b> | ไฟล์ถูกแทนที่หรือลบออก                  | deleteAfter + reason | cleanup ย้ายเข้า Trash เมื่อครบ 30 วัน |

**Legacy boundary** ระบบไม่ล้างและไม่แก้ไขไฟล์เดิมจาก Apps Script/โฟลเดอร์ Picture. เฉพาะไฟล์ที่ OAuth app สร้างและมี parent/lifecycle ตรงกับโฟลเดอร์ที่กำหนดจึงจะถูกจัดการ.

## 6.4 File rules

- อนุญาต JPEG/JPG, PNG, WebP และ PDF เท่านั้น.
- ขนาดต้องมากกว่า 0 และไม่เกิน 10 MB; 10 MB พอดีถือว่าผ่าน.
- extension, MIME type และ magic bytes ต้องสอดคล้องกัน; server ตรวจสอบผ่าน leading-byte range.
- ชื่อไฟล์ user ถูก sanitize และชื่อที่เก็บจริงใช้ SO-{order}-{timestamp}-{shortId}.{extension}; ไม่เก็บ original filename.
- thumbnail proxy จำกัด MIME เป็น image/jpeg/png/webp, ใช้ no-store และจำกัด response ไม่เกิน 2 MiB.

## 6.5 API contract

| Method | Path                                      | หน้าที่                          | ผลลัพธ์                            |
|--------|-------------------------------------------|----------------------------------|------------------------------------|
| GET    | /api/shop-order                           | load bootstrap                   | 200 { ok:true, data }              |
| POST   | /api/shop-order                           | create order + optional fileId   | 201 mutation result                |
| PATCH  | /api/shop-order                           | update by no + optional fileId   | 200 mutation result                |
| DELETE | /api/shop-order                           | clear order by no                | 200 { no }                         |
| POST   | /api/shop-order/upload-session            | validate metadata + open session | 201 session                        |
| PUT    | /api/shop-order/upload-proxy              | proxy bytes to Google URL        | 200 or safe upload error           |
| GET    | /api/shop-order/attachment-thumbnail?no=N | verified thumbnail               | 200 image or 404                   |
| GET    | /api/shop-order/cleanup                   | cron cleanup                     | Bearer secret + aggregate counters |

## 07 / SECURITY &amp; RESILIENCE

## ความปลอดภัยและความทนทาน

แนวทางของ Shop Order แยกความลับระหว่าง Sheets กับ Drive: Service Account มี scope spreadsheets; Drive ใช้ OAuth ของบัญชีเจ้าของเพียงบัญชีเดียวและ scope drive.file. ฟังก์ชัน client ไม่ได้รับ client secret, refresh token หรือ private key.

| พื้นที่ควบคุม               | มาตรการที่พบใน code                                                                                                        |
|-----------------------------|----------------------------------------------------------------------------------------------------------------------------|
| <b>Input validation</b>     | JSON content type, same-origin Origin check, 6-digit order, allowed department, strict date, MIME/extension/size/signature |
| <b>Secret handling</b>      | env-only; setup utility ไม่เขียน .env และไม่พิมพ์ access token; error response ไม่ส่ง Google body                          |
| <b>URL allowlist</b>        | upload session exact https://www.googleapis.com; thumbnail เฉพาะ *.googleusercontent.com; canonical Drive link เท่านั้น    |
| <b>Attachment ownership</b> | ตรวจสอบ file id, parent folder, appProperties, order number, metadata, trashed=false และ leading bytes                     |
| <b>Logging</b>              | Shop Order internal error log มี operation/category/correlationId; response ใช้ข้อความทั่วไป                               |
| <b>Cleanup auth</b>         | Bearer secret ตรวจสอบด้วย timingSafeEqual และคืน aggregate counters เท่านั้น                                               |
| <b>Traffic control</b>      | ระบบยัง public-by-link จึงต้องใช้ WAF rate limit mutation 30 requests/IP/10 นาที                                           |

## Public-access boundary

**ความเสี่ยงเชิงผลิตภัณฑ์** ไม่มีหน้า login และผู้เข้าถึง Production URL สามารถเรียก mutation API ได้. Same-origin check ช่วยลด browser CSRF บางกรณี แต่ไม่ใช่ authorization. URL governance และ WAF จึงเป็น defense-in-depth ที่จำเป็น.

สิ่งที่ควรทำใน Production คือจำกัดการเผยแพร่ URL, ตั้ง WAF ตาม path/method ที่กำหนด, ไม่ใส่ secret ใน URL/log, ติดตาม Vercel runtime logs และพิจารณา authentication/authorization หากข้อมูลหรือความเสี่ยงทางธุรกิจเพิ่มขึ้น.

## Failure modes ที่รองรับ

- Google Drive reauth/quota/folder/access/unavailable ถูก map เป็น safe error code ภาษาไทย.
- อัปโหลดไฟล์ล้มเหลวแต่บันทึก order สำเร็จได้ และ UI เปิดทางให้เพิ่มไฟล์อีกครั้ง.
- Sheet append/update/clear ล้มเหลวหลัง finalize จะพยายาม restore pending metadata และลบ permission ใหม่แบบ best effort.
- Cleanup เป็น idempotent: ไม่พบไฟล์หรือไฟล์ถูกย้าย Trash แล้วไม่นับเป็น failure ที่ทำให้ทั้งงานหยุด.
- thumbnail ใช้ authenticated proxy และ fallback เมื่อไม่พบรูปย่อ/ชนิดข้อมูลไม่ปลอดภัย/ขนาดเกิน.

## 08 / QUALITY

## การทดสอบและผลตรวจ

โครงการมี test coverage หนาแน่นที่สุดใน Shop Order และ navigation shell. ผลรันจริงของ snapshot นี้ช่วยยืนยันว่า behavior สำคัญผ่าน แต่ยังไม่เท่ากับการรับรอง Production แบบ end-to-end เพราะ browser manual acceptance และ live Google integration ไม่ได้รันในรอบนี้.

| กลุ่ม test     | สิ่งที่ตรวจ                                                                       |
|----------------|-----------------------------------------------------------------------------------|
| Domain         | วันที่, status, search/filter, sort, pagination, summary, 10,000-row stress shape |
| File rules     | MIME/extension/size/signature, sanitize filename, truncated bytes                 |
| Drive OAuth    | env, scope drive.file, error classification                                       |
| Repository     | A-K, append row, stable sequence, lifecycle, cleanup, thumbnail, compensation     |
| API handlers   | JSON, origin, validation, safe envelope, cron auth, proxy                         |
| UI interaction | navigation, shell drawer, PageHeader, dialogs, filters, upload failure            |
| Setup script   | loopback callback, state, offline consent, refresh token, folder creation         |

## ผลตรวจคำสั่ง

| สถานะ | คำสั่ง                                                                                                             | ผลตรวจ                                                     |
|-------|--------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------|
| PASS  | npm run test:unit                                                                                                  | Vitest 4.1.10: 25 test files, 270 tests                    |
| PASS  | npm run test:oauth-setup                                                                                           | Node test runner: 5 tests                                  |
| PASS  | npx tsc --noEmit                                                                                                   | TypeScript strict check                                    |
| PASS  | npm run build                                                                                                      | Next.js 16.2.12, Turbopack, 10 static pages + dynamic APIs |
| PASS  | npx eslint components/layout components/navigation app/layout.tsx app/ot-summary/page.tsx app/ot-employee/page.tsx | ส่วน shell/navigation/pilot ที่ตรวจแยก                     |
| FAIL  | npm run lint                                                                                                       | 154 problems: 144 errors, 10 warnings                      |

## รายละเอียด lint baseline

Full lint fail จากหลายกลุ่ม: explicit any ใน API/Google adapter, setState-in-effect ในบางหน้าและ Shop Order UI, unescaped quotes ใน BEM, unused vars ใน purchasing-all และ require() ใน scratch utilities. ปัญหาเหล่านี้ถูกบันทึกเป็น technical debt; ไม่ได้แก้ในรอบการจัดทำรูปเล่ม เพราะคำขอนี้เป็นงานอ่าน/จัดทำเอกสาร ไม่ใช่งานแก้ source.

## Browser verification handoff

เอกสาร verification วันที่ 31 กรกฎาคม 2026 ระบุว่า production server รันได้, /ot-employee และ /ot-summary ตอบ HTTP 200 และ automated checkpoint ผ่านที่ commit 3f3cbc6 แต่ browser automation ใน environment ถูก block ด้วย sandbox ACL และไม่มี Playwright/Puppeteer/Cypress. ดังนั้น viewport 360x800 ถึง 1366x768, focus/drawer, Back/Forward และ console diagnostics ยังเป็นรายการ pending.

**เกณฑ์การรายงาน** PASS ในส่วนนี้หมายถึงคำสั่งที่รันและผ่านจริง; PENDING หมายถึงยังไม่มีหลักฐานจาก browser/live service; ไม่ควรตีความว่า Production พร้อมสมบูรณ์โดยอัตโนมัติ.

## 09 / FINDINGS

## ข้อค้นพบและงานค้าง

รายการต่อไปนี้เป็นข้อสังเกตจากการอ่าน code และเอกสาร ไม่ใช่การแก้ไขในรอบนี้. การจัดระดับใช้ผลกระทบต่อความปลอดภัย ความถูกต้องของข้อมูล และความพร้อมดูแลระบบ.

| ระดับ | ข้อค้นพบ                                 | ผลกระทบ/คำแนะนำ                                                                                                   |
|-------|------------------------------------------|-------------------------------------------------------------------------------------------------------------------|
| สูง   | Public mutation API ไม่มี login          | ผู้เข้าถึง URL เรียก CRUD ได้; ต้องคุม URL/WAF หรือวาง auth ก่อนขยายการใช้งาน                                     |
| สูง   | Dashboard API คืน debugInfo 10 แถวแรก    | app/api/dashboard/route.ts ส่ง rawData.slice(0, 10) กลับ client; อาจเผยข้อมูลชี้ที่ไม่ควรอยู่ใน response          |
| กลาง  | full lint ไม่ผ่าน 144 errors/10 warnings | เพิ่มความเสี่ยง regression และทำให้ CI gate ที่ใช้ lint ไม่ผ่าน                                                   |
| กลาง  | UI shell migrate เพื่อ /ot-employee      | เป้าหมาย 7 routes ยังไม่ครบ; visual/interaction vocabulary ยังต่างกันระหว่างหน้า                                  |
| กลาง  | filter กลางใน Google Sheet               | dashboard/purchasing เขียนปี/เดือนลงเซลล์กลางและรอสูตร; concurrent users อาจเห็นข้อมูลตามคนอื่น                   |
| กลาง  | env contract ยังไม่เป็นชุดเดียว          | .env.example ไม่มี BEML/OT vars ที่ code ใช้; .env.local snapshot ไม่มี OAuth/cron vars ที่ Shop Order B1 ต้องใช้ |
| ต่ำ   | hard-coded sheet IDs/ranges              | การเปลี่ยน tab/column ต้องแก้ code และเพิ่ม operational runbook/contract test                                     |
| ต่ำ   | scratch ถูก lint รวม                     | utilities แบบ CommonJS ที่ไม่ใช่ runtime ทำให้ lint noise สูง; ควรแยก scope หรือปรับ config                       |

## ข้อเสนอแนะตามลำดับ

- แก้หรือเอา debugInfo ออกจาก public response และทบทวน error.message ของ legacy API ให้ใช้ safe error envelope แบบเดียวกับ Shop Order.
- กำหนด access model ให้ชัด: ถ้ายัง public ให้บังคับ WAF/URL governance; ถ้าข้อมูลมีความลับ ให้เพิ่ม authentication/authorization.
- จัดทำ env contract กลาง แยกกลุ่ม Dashboard, OT, BEML และ Shop Order พร้อมตรวจชื่อ GOOGLE\_SHEET\_ID กับ SHOP\_ORDER\_SHEET\_ID.
- ทำ lint baseline cleanup เป็นงานแยก: ย้าย scratch ออกจาก lint, ลด any, แก้ setState-in-effect และ unescaped entities.
- ทำ browser verification matrix ให้ครบทุก route/viewport และทดสอบ live Sheet/Drive ด้วย test order ที่ลบ/กู้ได้.
- เดินหน้า UI shell migration ตามแผน โดยรักษา route data behavior เดิมและเพิ่ม regression test ทุก route.

**ไม่ควรทำพร้อมกัน** อย่าเปิด Cache Components/Partial Prefetching หรือเปลี่ยน Next.js ระหว่าง shell migration โดยไม่มี version-matched guide และ data freshness/privacy review.



## 10 / RUNBOOK

## คู่มือ deploy และ runbook

## 10.1 เริ่มต้นในเครื่อง

```
npm install
Copy-Item .env.example .env.local
npm run dev
# เปิด http://localhost:3000/shop-order
```

ให้ใช้ Node.js/npm ตาม package-lock และตั้ง environment ให้ครบตาม capability ที่จะใช้งาน. อย่า commit .env.local, private key, OAuth client secret หรือ refresh token.

## 10.2 Environment matrix

| ตัวแปร                                  | ความสามารถ       | หน้าที่                                         |
|-----------------------------------------|------------------|-------------------------------------------------|
| GOOGLE_CLIENT_EMAIL                     | Sheets           | Service Account email                           |
| GOOGLE_PRIVATE_KEY                      | Sheets           | private key แบบมี \n ได้                        |
| GOOGLE_SHEET_ID                         | Dashboard/legacy | main dashboard sheet ที่ lib/googleSheet.ts ใช้ |
| SHOP_ORDER_SHEET_ID                     | Shop Order       | spreadsheet ของ Order1                          |
| SHOP_ORDER_SHEET_NAME                   | Shop Order       | ปกคือ Order1                                    |
| GOOGLE_OT_EMPLOYEE_SHEET_ID             | OT employee      | source spreadsheet                              |
| GOOGLE_OT_CONTRACTOR_SHEET_ID           | OT contractor    | source spreadsheet                              |
| GOOGLE_BEML_INVENTORY_SHEET_ID          | BEML             | ถ้าไม่ตั้งค่าจะเข้า demo mode                   |
| GOOGLE_DRIVE_OAUTH_CLIENT_ID            | Shop Order Drive | OAuth client                                    |
| GOOGLE_DRIVE_OAUTH_CLIENT_SECRET        | Shop Order Drive | server secret                                   |
| GOOGLE_DRIVE_OAUTH_REFRESH_TOKEN        | Shop Order Drive | refresh token ของเจ้าของ                        |
| SHOP_ORDER_DRIVE_FOLDER_ID              | Shop Order Drive | Picture-OAuth folder                            |
| SHOP_ORDER_CRON_SECRET /<br>CRON_SECRET | Cleanup          | ต้องตรงกันสำหรับ Vercel Cron                    |

## 10.3 ตั้งค่า Drive OAuth B1

- เปิด Google Drive API และตั้ง OAuth consent ให้บัญชี w10egat.project@gmail.com ใช้งานได้.
- สร้าง OAuth Client แบบ Desktop app แล้วตั้ง GOOGLE\_DRIVE\_OAUTH\_CLIENT\_ID/SECRET ขั้วคราวใน terminal.
- รัน npm run shop-order:setup-drive; เปิด URL ที่ utility แสดงเอง, อนุมัติ drive.file และรอ callback ที่ 127.0.0.1.
- คัดลอกเฉพาะ refresh token กับ Picture-OAuth folder ID ไปยัง secret manager/Vercel; ไม่ส่งผ่าน chat, screenshot หรือ log.

17. ตั้ง SHOP\_ORDER\_CRON\_SECRET และ CRON\_SECRET ให้ตรงกัน แล้ว redeploy.

## 10.4 Deploy verification

```
npm run test:unit
npm run test:oauth-setup
npx tsc --noEmit
npm run build
npm run lint # ต้องแก้ baseline ก่อนใช้เป็น hard gate
```

| พื้นที่ตรวจ        | Acceptance check                                                 |
|--------------------|------------------------------------------------------------------|
| <b>Application</b> | เปิดทุก route และตรวจ loading/error/empty state                  |
| <b>Dashboard</b>   | เปลี่ยนปี/เดือนและตรวจไม่ให้ filter ของผู้อื่นซ้อนทับ            |
| <b>Shop Order</b>  | สร้างเลข 6 หลักพร้อม PNG/JPEG ขนาดเล็ก, ตรวจ Order1 และ Drive    |
| <b>Replacement</b> | แก้รายการด้วย PDF แล้วตรวจไฟล์เดิมเป็น scheduled_delete          |
| <b>Failure</b>     | จำลอง upload fail; order ต้องถูกบันทึกและมีปุ่มเพิ่มไฟล์อีกครั้ง |
| <b>Cleanup</b>     | เรียก cleanup ด้วย Bearer ที่ถูกต้อง; secret คิดต้องได้ 401      |
| <b>Security</b>    | ตรวจ WAF 30 requests/IP/10 นาที และห้าม session URL อยู่ใน logs  |

## 10.5 Troubleshooting ที่พบบ่อย

| อาการ                      | แนวทาง                                                                         |
|----------------------------|--------------------------------------------------------------------------------|
| <b>GET Shop Order 500</b>  | ตรวจ Sheets service account, private key และสิทธิ์ Editor ใน spreadsheet       |
| <b>Drive configuration</b> | ตรวจ OAuth 3 ค่าและ folder ID ของ Picture-OAuth; ไม่ใช่โฟลเดอร์ Picture legacy |
| <b>Drive 403/404</b>       | ตรวจ quota, Drive API, folder ownership และสิทธิ์ของ OAuth client              |
| <b>ไม่มี refresh token</b> | ถอนสิทธิ์แอปแล้วรัน setup ใหม่ด้วย prompt=consent                              |
| <b>thumbnail ไม่ขึ้น</b>   | กด refresh; ตรวจว่าไฟล์ active, ไม่อยู่ Trash และเป็นชนิดที่รองรับ             |
| <b>upload fail</b>         | client retry network/timeout/429/5xx; 4xx จะไม่ retry และ order ยังบันทึกได้   |

## 11 / APPENDIX

## ภาคผนวก

## 11.1 File map ที่ควรรู้

| ไฟล์/กลุ่มไฟล์                           | บทบาท                                               |
|------------------------------------------|-----------------------------------------------------|
| app/layout.tsx                           | Root metadata, Prompt font, ShellMigrationGate      |
| app/page.tsx                             | Home dashboard client page                          |
| app/purchasing/page.tsx                  | PurchasingPageContent + purchasing UI               |
| app/ot-summary/page.tsx                  | Shared OT content for contractor/employee           |
| components/layout/*                      | AppShell, sidebar, drawer, PageHeader, route chrome |
| components/navigation/*                  | Canonical destinations + NavigationMenu             |
| components/shop-order/*                  | Shop Order dashboard, table, form, dialogs          |
| lib/googleSheet.ts                       | Sheets client and source-specific readers           |
| lib/shop-order/repository.ts             | CRUD, Drive session, finalize, thumbnail, cleanup   |
| lib/shop-order/domain.ts                 | date conversion, filters, sort, summary, pagination |
| lib/shop-order/file-rules.ts             | approved file types and signatures                  |
| lib/shop-order/attachment-lifecycle.ts   | pending/active/scheduled-delete state               |
| scripts/setup-shop-order-drive-oauth.mjs | local loopback OAuth setup utility                  |
| vercel.json                              | daily cleanup cron at 17 18 * * * UTC               |

## 11.2 Glossary

| คำศัพท์                | ความหมายในโครงการ                                                                  |
|------------------------|------------------------------------------------------------------------------------|
| <b>Order1</b>          | ชื่อหลักของ Shop Order; โครงสร้างข้อมูล A-K                                        |
| <b>ETAS Scan Data</b>  | ข้อมูลสแกนเวลา ใช้ประกอบตาราง OT ของ worker type เดียวกัน                          |
| <b>drive.file</b>      | Google Drive scope ที่แอปจัดการเฉพาะไฟล์/โฟลเดอร์ที่สร้างหรือได้รับสิทธิ์ผ่านแอป   |
| <b>Pending upload</b>  | ไฟล์ที่สร้าง session แล้วแต่ยังไม่ถูกผูกกับ order                                  |
| <b>Partial success</b> | Sheet order บันทึกสำเร็จ แต่ attachment ไม่สำเร็จ; UI ต้องให้ลองเพิ่มไฟล์ภายหลัง   |
| <b>Legacy file</b>     | ไฟล์/โฟลเดอร์เดิมจาก Apps Script ที่ OAuth B1 ไม่แก้และไม่ล้าง                     |
| <b>no-store</b>        | response/cache policy ที่ใช้ป้องกันข้อมูล dashboard/thumbnail ค้าง                 |
| <b>WAF</b>             | Web Application Firewall; ในระบบนี้ใช้จำกัด mutation traffic เป็น defense-in-depth |

## 11.3 แหล่งข้อมูลที่ใช้ทำรูปเล่ม

- README.md, PRODUCT.md, CONTEXT.md และ AGENTS.md
- app/, components/, lib/ และ scripts/ ใน repository snapshot
- docs/superpowers/specs/ และ docs/superpowers/plans/

- docs/superpowers/verification/2026-07-31-task5-browser-verification-handoff.th.md
- ผลคำสั่ง `npm run test:unit`, `npm run test:oauth-setup`, `npx tsc --noEmit`, `npm run build`, `npm run lint` และ `scoped ESLint`

**ขอบเขตความรับผิดชอบ** รูปเล่มนี้เป็นเอกสารวิเคราะห์และ `runbook` จาก `code snapshot`; ไม่ได้เปลี่ยน API, schema, environment, WAF หรือ source behavior ของโปรเจกต์.

จบเอกสาร